THREAT-INTELLIGENCE INVESTIGATION · CASE PHI-2026-001

Recruitment-Lure Phishing Targeting a Blockchain Researcher

First-hand analysis of a live phishing lure impersonating Linea via the lookalike domain `lineatalent.xyz` — reconstructed end to end from the preserved message using passive OSINT only.

EXAMINER
Paulo Vaz

CASE REFERENCE
PHI-2026-001

LURE RECEIVED
2026-10-05 · 09:37 UTC

INVESTIGATION WINDOW
2026-10-05 → 2026-10-08

METHOD
Passive OSINT · Email forensics

DISPOSITION
Reported · Not engaged

Confidential — portfolio case study. Prepared for professional review. Conducted entirely on a message the examiner personally received; no attacker infrastructure was contacted and no sender-supplied link or file was engaged. Contains no third-party personal data beyond what is necessary to document the finding.

00 Document control & summary

Case reference	`PHI-2026-001`
Case name	Recruitment-Lure Phishing — Linea Lookalike (`lineatalent.xyz`)
Examiner	Paulo Vaz
Investigation type	Passive OSINT · email-header forensics · threat intelligence
Target of the lure	The examiner's own personal inbox
Lure received	2026-10-05 09:37:43 UTC
Investigation window	2026-10-05 → 2026-10-08
Primary evidence	Preserved raw `.eml` + 5 captured public-source records (hashed)
Disposition	Message preserved and reported to the mailbox provider; sender, link and verification code never engaged
Attribution	None asserted — TTP-level characterisation only

Executive summary

On 2026-10-05 a targeted recruitment email impersonating the blockchain company **Linea** was received. It offered an engineering role and drove the recipient toward `lineatalent.xyz` — a lookalike of Linea's real domain, `linea.build`, registered just **8 days earlier**.

Passive analysis of the preserved message established that it was sent through **Amazon SES (São Paulo region)** via the **Resend** email platform, carried a **hidden open-tracking beacon**, and passed **SPF, DKIM and DMARC** — not because it was legitimate, but because the operator **controlled the lookalike domain**. The linked page was a brand-cloned "Linea | Careers" site on **separate hosting**, not yet flagged by reputation engines owing to its newness. The operation's tactics are **consistent with recruiter-lure social engineering targeting crypto/blockchain professionals** — a documented pattern — but the evidence does **not** support attribution to any named actor.

CENTRAL FINDING

SPF / DKIM / DMARC all passing is **not** evidence of legitimacy. Those mechanisms prove only that a message genuinely came from the domain it claims and was unaltered in transit. An attacker who registers their own lookalike domain and configures it correctly passes all three — precisely because they own the domain. Here, authentication passing is a direct consequence of the attacker controlling `lineatalent.xyz`.

The recipient did not engage: no reply, no link, no verification code, no download. This report reconstructs the investigation in the order it was conducted and separates, throughout, what the evidence **shows** (fact) from what can be **reasoned** from it (inference) and from **who** was responsible (attribution — not established).

01 Scope, method & rules of engagement

The question: **a targeted recruitment email impersonating Linea was received — is it legitimate, and if not, what can be established about the operation behind it using only passive, public sources?**

The investigation does not attempt to unmask a named individual or company. OSINT of this kind characterises **infrastructure and behaviour**; it cannot, on this evidence, identify a person. That boundary was fixed at the outset and respected through to the attribution phase.

Rules of engagement

- **Passive only** — public lookup services and the preserved message. No scanning or probing of attacker infrastructure.
- **The landing page is observed through a sandbox** (urlscan.io), never from the examiner's own browser or network.
- **No engagement with the sender** — no reply, no use of the verification code, nothing downloaded or executed.
- **Preserve before analyse** — the `.eml` was exported and hashed before any interpretation.
- **Examine from raw source** — so the embedded open-tracking pixel was never fetched.

WHY THE DISCIPLINE MATTERED IN PRACTICE

The message body carries a hidden 1×1 tracking image on the attacker's own subdomain. Rendering the HTML in a normal client would have silently loaded it and signalled "this human opened the mail" back to the operator. Reading the message from raw source kept that beacon inert — the safety rule produced a concrete evidentiary benefit, not just caution.

Provenance over custody

OSINT has no seized artifact to take custody of; the equivalent discipline is **provenance** — recording the source queried, the exact query, the UTC time, and whether the source is authoritative or a relay. Every collection action in this case is logged that way. The one item held in true custody is the raw message itself, fixed by SHA-256 before analysis.

STANDARD	ROLE IN THIS INVESTIGATION
ISO/IEC 27037	Identification, collection and preservation of evidence (adapted to OSINT provenance)
ISO/IEC 27041	Assurance that the methods are suitable and the results reliable
ISO/IEC 27042	Analysis and interpretation of digital evidence
ISO/IEC 27043	Incident-investigation principles and process
NIST SP 800-61r2	Incident handling — detection, analysis, reporting
RFC 5322 / 7208 / 6376 / 7489	Message format / SPF / DKIM / DMARC — the authentication basis
RFC 3227	Evidence-collection and archiving discipline (provenance)
LGPD (Lei 13.709/2018)	Handling of the targeted data subject's own personal data
MITRE ATT&CK (Enterprise)	Technique mapping for the observed behaviour

02 Evidence register

Six items, each fixed by SHA-256 at staging. Full hash manifest in the repository collection log.

ID	ITEM	SOURCE	AUTHORITY
E1	Raw message `.eml` (full headers + body)	Recipient mailbox export	Primary artifact
E2	Rendered message (screenshot)	Mailbox web UI	Primary artifact
E3	WHOIS — `lineatalent.xyz`	who.is	Third-party relay
E4	WHOIS — `linea.build`	who.is	Third-party relay
E5	Sandboxed page scan	urlscan.io	Analysis platform
E6	Certificate Transparency records	crt.sh	Authoritative (relay)



E2 — the lure as received. Sender `lisabeck@hr.lineatalent.xyz`; hook referencing the recipient's public GitHub/blockchain activity; link to `lineatalent.xyz` with a "verification code".

03 Initial triage

Why the message warranted investigation rather than a one-click delete — each point an observation at this stage, confirmed against the raw evidence in later sections.

Not Linea's real domain

OBSERVED — Sender domain `hr.lineatalent.xyz` and link `lineatalent.xyz`; Linea's genuine domain is `linea.build`.

INTERPRETATION — A plausible-looking **lookalike** built on the brand token “linea” plus a context word “talent”.

CONFIDENCE — HIGH

The lure is tailored, not generic

OBSERVED — The hook reads “Your GitHub activity in blockchain repos stood out.” The recipient had recently published blockchain-investigation work publicly.

INTERPRETATION — This is **targeting** keyed to a visible professional profile, not a broadcast spam.

CONFIDENCE — MEDIUM–HIGH

Automated, shallow personalisation

OBSERVED — Greeting reads “Hi **phvaz**” — the local-part of the recipient's email address, not a real first name.

INTERPRETATION — Cheap automated personalisation; the operator does **not** actually know the recipient's name.

CONFIDENCE — HIGH

Legitimacy-and-urgency device

OBSERVED — A “verification code” `Ref-4h31zzxmmutk76` to be used on the careers page.

INTERPRETATION — Manufactures a sense of a real, tracked application process and nudges the target onto the attacker's page.

CONFIDENCE — MEDIUM

THE DECISIVE TRIAGE JUDGEMENT

An unsolicited recruiter citing the recipient's recently-published blockchain work, from a domain that is not Linea's, is the textbook shape of a **recruitment lure aimed at a person because of their visible security/crypto profile**. That judgement set the posture for the whole case: treat the message, the link, and anything the sender offers as hostile, and investigate only by passive and sandboxed means.

04 Email-header analysis

Headers written by transit and receiving infrastructure (Google, Amazon) are far harder to forge than a `From:` line — they are the load-bearing evidence.

4.1 Authentication results

The receiving server recorded `dkim=pass` (for both `hr.lineatalent.xyz` and `amazonses.com`), `spf=pass` and `dmarc=pass (p=NONE)`.

Authentication confirms control, not legitimacy

OBSERVED — All three checks pass for `(hr.)lineatalent.xyz`; DMARC policy is `p=NONE`.

INTERPRETATION — The sender legitimately controls the lookalike domain and configured it properly. Passing authentication proves **domain control**, not **trustworthiness**. `p=NONE` means no enforcement — typical of a throwaway attack domain built for deliverability.

CONFIDENCE — HIGH

4.2 Real origin — Amazon SES, São Paulo

Four independent, Amazon-set header elements converge: the `Received` from-host `d215-51.smtp-out.sa-east-1.amazonses.com`, a `Message-ID` on `@sa-east-1.amazonses.com`, `X-SES-Outgoing: 2026.10.05-23.249.215.51`, and a `Feedback-ID` ending `:AmazonSES`.

The message transited Amazon SES (sa-east-1)

OBSERVED — Reverse-DNS host, Message-ID, X-SES-Outgoing and Feedback-ID all name the `sa-east-1` region.

INTERPRETATION — The operator used a legitimate, high-reputation cloud mail service for deliverability into Gmail. These headers are set by **Amazon**, not the sender, so the origin is reliable. Region choice is an infrastructure fact, not the location of a person.

CONFIDENCE — HIGH

4.3 The ESP layer — Resend over SES

A purpose-built transactional-email pipeline

OBSERVED — DKIM selector `s=resend`, a `rsend.hr.lineatalent.xyz` Return-Path, and a second DKIM signature from `amazonses.com`.

INTERPRETATION — The operator stood up a proper pipeline — a developer ESP (Resend) delivering through SES, with a verified sending subdomain and DKIM keys. Deliberate engineering effort; an **organised operation**, not a hijacked account.

CONFIDENCE — HIGH

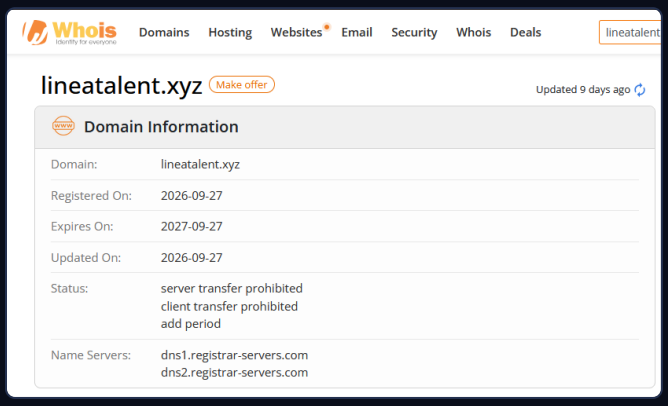
4.4 Open-tracking beacon

A per-recipient open-tracking pixel

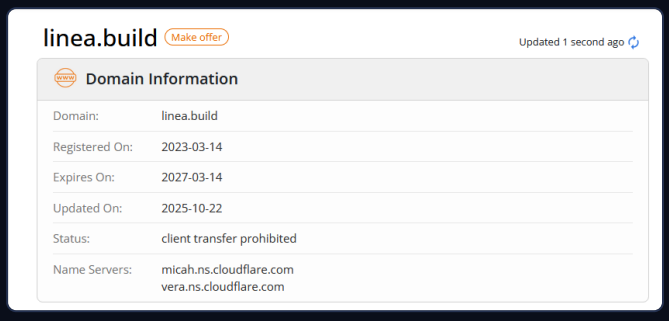
OBSERVED	A 1×1, `display:none` image on `open.hr.lineatalent.xyz` carrying a per-message token.
INTERPRETATION	If loaded, it reports the exact moment this specific recipient opened the mail — confirming a live, engaged human and enabling prioritised follow-up. Infrastructure configured for **campaign measurement**.
CONFIDENCE	HIGH

05 Domain & infrastructure

5.1 WHOIS — lookalike vs genuine



E3 — `lineatalent.xyz`: registered 2026-09-27, Namecheap, status incl. `addPeriod`.



E4 — `linea.build`: registered 2023-03-14, Cloudflare nameservers.

FIELD	LINEATALENT.XYZ (LOOKALIKE)	LINEA.BUILD (GENUINE)
Registered	**2026-09-27**	2023-03-14
Updated	2026-09-27	2025-10-22
Registrar	Namecheap	Cloudflare-managed
Nameservers	registrar-servers.com (default)	ns.cloudflare.com
Status	+ `addPeriod` (first days only)	clientTransferProhibited

Registered 8 days before the lure

OBSERVED — The lookalike was created **2026-09-27**; the email arrived 2026-10-05. The genuine domain is **~3.5 years older**. The `addPeriod` status flag appears only in the first days after registration.

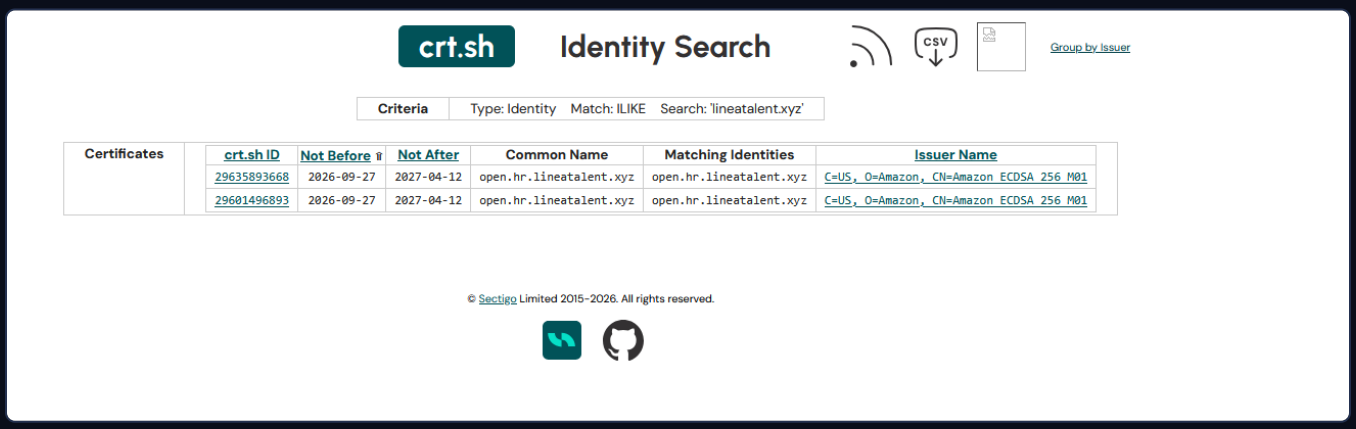
INTERPRETATION — A disposable, single-purpose domain stood up specifically for this campaign and used almost immediately. A newly-registered close match to a brand is a strong phishing indicator; the age gap cleanly separates fake from real.

CONFIDENCE — HIGH

ON THE LOOKALIKE ITSELF

`lineatalent.xyz` is not a character-swap homoglyph — it is a **plausible-sibling**: it reuses the real brand token ("linea") and bolts on a context word ("talent") under a cheap TLD, reading as "Linea's careers site" to anyone not checking against `linea.build`. The more effective strategy against a target who knows the brand but not its exact domain.

5.2 Certificate Transparency (crt.sh)



E6 — CT records: two Amazon-issued certificates for `open.hr.lineatalent.xyz`, Not Before 2026-09-27.

CT independently corroborates the AWS tracking subdomain

OBSERVED — A publicly-logged, append-only certificate exists for `open.hr.lineatalent.xyz`, issued by **Amazon**, **Not Before 2026-09-27** — the same day the domain was registered.

INTERPRETATION — Two separate evidence layers — the SMTP headers and the CT log — now point to the same AWS-hosted tracking endpoint. **Convergence** from independent sources is what gives a finding weight. Domain, DNS and TLS were all stood up in one session.

CONFIDENCE — HIGH

Email and web legs are separate infrastructure

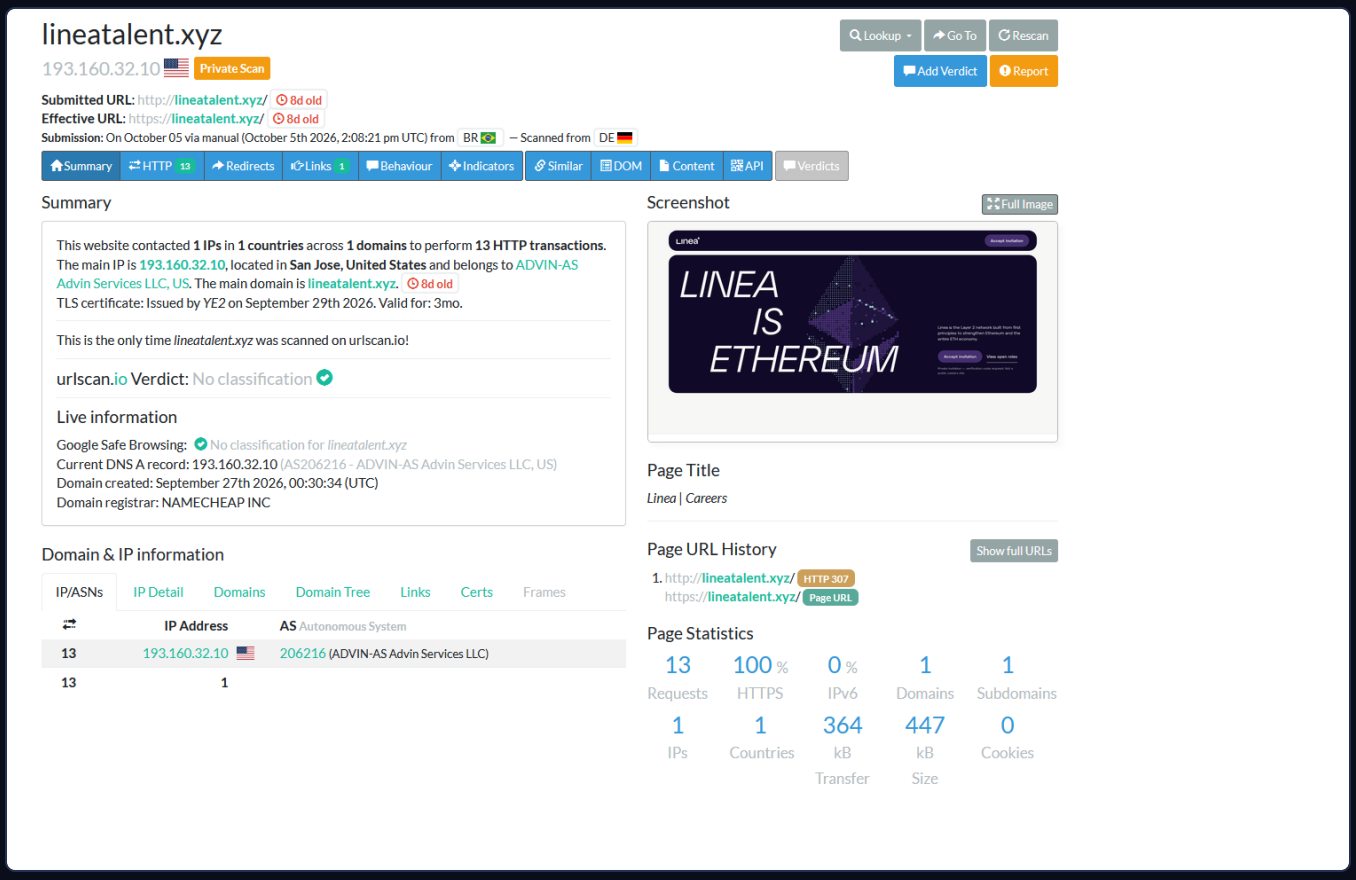
OBSERVED — The landing-page certificate (issuer "YE2", §06) does not appear here — only the Amazon-issued tracking cert does.

INTERPRETATION — Consistent with a **compartmentalised** setup: AWS for email + tracking, a different provider/CA for the web page. Recorded as an inference from an absence, so held at medium confidence.

CONFIDENCE — MEDIUM

06 Landing-page analysis (sandboxed)

What `https://lineatalent.xyz/` serves — observed only through urlscan.io's isolated environment, never visited directly.



E5 — urlscan.io: a brand-cloned “Linea | Careers” page on `193.160.32.10` (AS206216, San Jose); 13 requests; both urlscan and Google Safe Browsing “No classification”.

Effective URL	`https://lineatalent.xyz/` (HTTP 307 → HTTPS)
Host IP	`193.160.32.10` — San Jose, US
ASN	AS206216 — ADVIN-AS, Advin Services LLC
TLS certificate	Issuer “YE2”, issued 2026-09-29, 3-month validity
Page title	Linea | Careers
Reputation	urlscan & Google Safe Browsing: **No classification**

A brand-cloned careers front with a scripted funnel

OBSERVED — A dark, Linea-styled page headed “LINEA IS ETHEREUM” with an “Accept invitation” CTA, paired with the email's verification-code mechanic.

INTERPRETATION — A convincing impersonation front that converts a passive reader into an active participant. The next stage (credential capture, wallet connection, or a malicious “assignment”/ download) would be delivered behind the CTA — **deliberately not exercised**, as doing so would mean engaging the attack.

CONFIDENCE — MEDIUM

Not classified is not safe

OBSERVED — Both urlscan and Google Safe Browsing returned “No classification”; the page's TLS cert was issued two days after registration.

INTERPRETATION — The domain was too new to be catalogued — detection lag, not a clean bill of health. Valid HTTPS is trivial for an attacker to obtain and carries no trust signal. The lure was sent inside this freshness window.

CONFIDENCE — HIGH

THE OPERATIONAL CORE

A freshly-registered, correctly-authenticated, HTTPS-secured, brand-cloned domain has a window — days to weeks — in which it passes every automated and visual trust check a non-expert applies. This lure was sent **8 days** into that window.

07 Attribution & pattern correlation

STATED UP FRONT

This investigation does **not** attribute the campaign to any named person, company or threat group. What follows is a TTP-level characterisation and a comparison to a publicly documented pattern. Those are different claims from "who did this", and the difference is kept explicit.

7.1 MITRE ATT&CK mapping

TACTIC	TECHNIQUE	ID
Resource Development	Acquire Infrastructure: Domains	T1583.001
Resource Development	Acquire Infrastructure: Web Services	T1583.006
Resource Development	Establish Accounts: Email Accounts	T1585.002
Reconnaissance	Gather Victim Identity Information	T1589
Initial Access	Phishing: Spearphishing Link	T1566.002
Reconnaissance	Phishing for Information: Spearphishing Link	T1598.003
Defense Evasion / Social Eng.	Impersonation	T1656
Execution (intended, not exercised)	User Execution: Malicious Link	T1204.001

7.2 The pattern it fits

An unsolicited recruiter approach; a target selected for a public blockchain/crypto profile; impersonation of a real crypto company via a lookalike domain; a two-step funnel (friendly email → attacker-controlled page); and well-resourced delivery. This combination is a **publicly documented social-engineering pattern**, reported under names such as **"Operation Dream Job"** and **"Contagious Interview"** and associated in open reporting with DPRK-nexus activity (the TraderTraitor/Lazarus cluster). The present case matches that pattern **at the level of tactics and techniques.**

CLAIM	STATUS	CONFIDENCE
Uses a recruiter-lure TTP targeting crypto/blockchain professionals	FACT	High
Resembles the documented "Dream Job"/"Contagious Interview" pattern	INFERENCE	Medium–High
Is the work of Lazarus/TraderTraitor or any named group	NOT ESTABLISHED	—
"Lisa Beck" is a real, identified person	NOT ESTABLISHED	—

The TTP is widely used — including by financially-motivated criminals with no state link — so resemblance to a famous campaign is **not** proof of the same author. A named attribution would require evidence this passive, single-message investigation cannot have: infrastructure reuse tied to prior confirmed operations, malware samples, or privileged reporting. "Lisa Beck" is a sending **persona/account**, not an identified individual.

7.3 Intent (kept separate from attribution)

Funnel the target into a controlled next stage

OBSERVED	Recruitment pretext + attacker-controlled “careers” page + verification-code mechanic + open-tracking.
INTERPRETATION	To move the target off email into a controlled environment where credential capture, wallet connection, or a malicious coding “assignment” could be delivered, and to identify live targets for follow-up. An inference about **purpose**, held separately from fact and from attribution.
CONFIDENCE	MEDIUM–HIGH

08 Consolidated timeline

All times UTC. Registration corroborated by three independent sources (WHOIS, urlscan, CT).

WHEN (UTC)	EVENT	SOURCE
2026-09-27 00:30:34	Domain `lineatalent.xyz` registered	urlscan / WHOIS
2026-09-27	Amazon TLS cert issued for `open.hr.lineatalent.xyz` (tracking subdomain)	crt.sh
2026-09-29	Landing-page TLS cert issued (issuer “YE2”)	urlscan
2026-10-05 09:37:43	Lure email sent via Amazon SES (sa-east-1) / Resend; delivered to target	E1 headers
2026-10-05	Target preserves the message; sandboxed page scan captured; no engagement	E1, E5
2026-10-06	WHOIS of both domains captured and compared	E3, E4
2026-10-08	Certificate Transparency records captured	E6

The operation's assets were built in a single window on 2026-09-27 and weaponised eight days later. By the time of analysis the domain was still too new for reputation engines to have flagged it.

09 Indicators of compromise

ACTION CAVEAT

Shared, legitimate cloud infrastructure (Amazon SES, Resend) appears here only because the operator rented it. **Do not blocklist AWS/SES/Resend or the SES sending IP.** Only the attacker-owned domain, subdomains, sender address, landing-page IP and URL are safe to action.

TYPE	INDICATOR	ACTION
Domain	`lineatalent.xyz`	Block / monitor
Subdomain	`hr.lineatalent.xyz` · `rsend.hr.lineatalent.xyz` · `open.hr.lineatalent.xyz`	Block / monitor
URL	`https://lineatalent.xyz/`	Block
Sender	`lisabeck@hr.lineatalent.xyz`	Block
IPv4 (page host)	`193.160.32.10` — AS206216 ADVIN-AS	Block (host-specific)
IPv4 (SES send)	`23.249.215.51`	**Do not block** — shared SES
Lure string	Verification code `Ref-4h31zzxmmutk76`	Detect

10 Recommendations, limitations & statement

Recommendations

Individual target

- Do not reply, click, or use the verification code. ✓ done
- Preserve the raw message and report it to the mailbox provider. ✓ done
- Report the domain to the registrar's abuse channel and to Linea's real security contact.
- Submit the URL/domain to reputation feeds to shorten the detection gap for the next target.

Defenders / organisations

- Treat **domain age + lookalike similarity** as a first-class signal — SPF/DKIM/DMARC passing is necessary but not sufficient.
- Flag unsolicited recruiter emails that cite an employee's public code/research and link to a non-canonical domain.
- Teach that a padlock and a clean “authenticated” banner mean nothing on an attacker-owned domain; the check that works is “is this the brand's real, established domain?”

Tradecraft lessons

- Examine suspected phishing from raw source — never render it.
- Observe hostile pages only through a sandbox.
- Keep **authentication ≠ legitimacy** front of mind — the single most load-bearing correction this case teaches.

Limitations

- **Single message** — the full campaign's scale is unknown from this evidence.
- **Passive only** — the landing page's post-CTA behaviour was characterised but not exercised.
- **Perishable data** — WHOIS/DNS/hosting reflect 2026-10-05→08 and may since have changed; the preserved `.eml` and screenshots are the fixed record.
- **No attribution** — by design and by evidence, the operator is not named.

Examiner's statement

This investigation was conducted on a message I personally received, using passive open-source methods only. No attacker infrastructure was contacted, no sender-supplied link or file was engaged, and the landing page was observed exclusively through a third-party sandbox. Findings are separated into fact, inference and attribution, with confidence stated for each; where the evidence does not support a conclusion — including the identity of the operator — the report says so. The raw message and all captured records are preserved and fixed by SHA-256.

Examiner	Paulo Vaz
Case	PHI-2026-001
Report date	2026-10-08
Signature	_____